Grupo Bimbo, S.A.B. de C.V. | ESG Scores Raw Data

BMV:BIMBO A (MI KEY: 4276592; SPCIQ KEY: 877906; TCUID: 53231)

Public

Year: Methodology Year: 2026
Question: Information Security Policy
Include Modeled Scores : Yes

Information Security Policy

Question

Does the company have a policy on information security and is it available publicly?

Rationale

The purpose of this question is to assess a company's commitment to managing information security risks through transparent public reporting. As the reliance on digital information grows, safeguarding data and ensuring the resilience of information systems have become critical factors in both corporate sustainability and risk management. Effective information security policies are essential to protect against cyber threats, data breaches, and system vulnerabilities, which can impact not only a company's operations but also its reputation and long-term value generation.

This question examines whether the company publicly discloses its information security policy, highlighting key commitments such as continuous investment in IT infrastructure, to ensuring data integrity and responsiveness to cybersecurity threats. Additionally, it evaluates the company's application of security requirements to third parties (e.g., suppliers).

Performance Summary	
Question Level Company Performance	0
Question Weight	30
Year-on-Year Change	0
Industry Average Score	14
Industry Highest Score	100

The question layout and the company's verified information is provided below. No information is shown if the company did not provide any information or if it opted out of sharing non-public information.

Additional Question Guidance & Information Display

Key Definitions

Information Security: It refers to the comprehensive measures taken to protect an information technology system from threats including malicious attacks, data loss, service disruptions, and any damage to its hardware, software, and stored data. The primary objective of information security is to mitigate information risk by ensuring the confidentiality, integrity, and availability of information.

Information Security Policy: A formal declaration of the company's commitment to implementing and maintaining standards for protecting information systems. This policy outlines the promises made regarding data protection, continuous security improvements, and adherence to cybersecurity best practices, both internally and in partnership with external stakeholders.

Continuously improving information security systems: Information security risks are not static; risks might vary and evolve depending on different circumstances, which is why continually improving the information security management system is important to protect and create value.

Ensuring integrity and protection of data: Ensuring that data remains accurate, consistent, and safeguarded from unauthorized access, tampering, or destruction. This involves maintaining security controls that protect data throughout its lifecycle, including measures to prevent breaches and ensure that only authorized users can modify or access sensitive information.

Monitoring and responding to information security threats: Actively monitoring cybersecurity risks, responding to incidents promptly, and implementing mitigation strategies. This includes maintaining transparency with affected stakeholders when breaches or threats occur, outlining actions taken to address vulnerabilities and prevent future risks.

Establishing individual responsibilities for the entire workforce: The establishment of responsibilities for the entire workforce pertaining to information security. All employees are expected to have varying degrees of responsibility for information security, even if their responsibilities consist only in flagging suspicious activities. If the company's information security guidelines are applicable to the entire workforce, and are accompanied by defined actions, this would be acceptable since the entire workforce would need to follow them.

Establishing information security requirements for third parties (e.g., suppliers): The establishment of information security requirements for third parties, which list the security policies that they are expected to comply with to work with the company. This approach aims to mitigate risks associated with external relationships and safeguard shared infrastructures and data.

Important note: *For the purpose of this question, references containing "information security", "cybersecurity" and "IT security" and similar terms are all equally accepted.*

Disclosure Requirements

- Disclosure requirements for public questions: Companies are expected to provide relevant publicly available evidence to support their claims.
- Please note that the assessment expectations require evidence of the existence of the listed documents/processes. Reports containing sensitive information are not required for the options to be accepted.

References

ISO/IEC 27001:2022 Information security, cybersecurity and privacy protection — Information security management systems — Requirements

Data View

QUESTION LEVEL INPUT	COMPANY ANSWER
Company publicly reports on its information security policy.	Not measured
Company's information security policy includes a commitment to continuous improvement in IT systems.	Not measured
Company's information security policy includes a commitment to the integrity and protection of data.	Not measured
Company's policy commits to monitor and respond to cybersecurity threats.	Not measured
Company's information security policy includes the establishment of individual responsibilities for the entire workforce.	Not measured
Company's information security policy includes applicable requirements for third parties.	Not measured

Questionnaire

Does the company have a policy on information security and is it available publicly?

1. ○ Yes, the company has a policy on information security. Please indicate where this information is available in **public reporting or corporate website.**
   1. ☐ Continuously improving information security systems
   2. ☐ Ensuring integrity and protection of data
   3. ☐ Monitoring and responding to information security threats
   4. ☐ Establishing individual responsibilities for information security for the entire workforce
   5. ☐ Establishing information security requirements for third parties (e.g. suppliers)
2. ◉ No, the company does not publicly report on a policy on information security.
3. ○ The question is not applicable to the company.

Confidential additional comments

Use the text field below only in the following cases: (i) to describe significant changes in data or calculation methodology compared to last year's submission, (ii) to explain why a question is not applicable to your company's business model, (iii) to explain if your data deviates from the unit or format requested, or (iv) to provide supporting notes on translations of non-English references.